

Access Control Incident Analysis

Investigating an Unauthorised Payroll Transfer & Recommending Security Controls

Domain Access Control / IAM	Skills Applied Log Analysis, Threat ID, Risk Mitigation	Difficulty Beginner	Status Completed
---------------------------------------	--	-------------------------------	----------------------------

Project Overview

This activity is part of the Google Cybersecurity Certificate curriculum. As the first cybersecurity professional hired by a growing business, I was tasked with investigating an unauthorised payroll transfer to an unknown bank account. The finance manager confirmed no mistake was made on their end, and fortunately the payment was stopped before it cleared. My objective was to analyse the event log, identify the threat actor, uncover the access control weaknesses that were exploited, and recommend mitigations to prevent recurrence.

Scenario

A deposit was made from the business to an unknown bank account (labelled FAUX_BANK). The business operates a shared cloud drive accessible to all employees, with no apparent role-based restrictions. I was given access to the system event log and the employee directory to conduct my investigation.

Investigation Process

Step 1 — Review the Event Log

I examined the event log for the payroll incident, focusing on the Event Type, Date, Time, User, Computer, and IP Address fields:

Field	Value
Event Type	Information
Event Source	AdsmEmployeeService
Event ID	1227
Date	10/03/2023
Time	8:29:57 AM

User	Legal\\Administrator
Computer	Up2-NoGud
IP Address	152.207.255.255
Description	Payroll event added. FAUX_BANK

Key observations: The user account logged as `Legal\\Administrator` accessed the payroll system from IP `152.207.255.255` using a machine named `Up2-NoGud` — an unusual hostname suggestive of a personal, non-company device.

Step 2 — Cross-Reference the Employee Directory

I compared the IP address and user account from the event log against the employee directory. The IP address `152.207.255.255` matched Robert Taylor Jr., a legal attorney who worked as a contractor. Critically, his employee record showed an end date of approximately November 2020 — nearly three years before this incident occurred in October 2023.

This immediately raised a red flag: a former contractor's account was still active, had full Admin-level access, and was used to trigger a fraudulent payroll transaction.

Step 3 — Identify Access Control Failures

Reviewing the full employee directory revealed a systemic problem: every single employee, regardless of their role, employment type (full-time, part-time, seasonal, contractor), or current status, had been assigned Admin-level authorisation. This included a graphic designer, sales associates, and seasonal workers — none of whom have any legitimate need for access to financial or payroll systems.

Completed Access Control Worksheet

The following worksheet summarises my investigation findings, identified issues, and recommendations:

	Note(s)	Issue(s)	Recommendation(s)
Authorization / Authentication	The event log shows a payroll transaction was added on 10/03/2023 at 8:29:57 AM by user <code>Legal\\Administrator</code> from IP <code>152.207.255.255</code> , directing funds to FAUX_BANK. Cross-referencing the employee directory, this IP matches	Robert Taylor Jr. retained Admin-level access for nearly 3 years after his contract ended. No offboarding process removed his account, allowing him to access the payroll system. Every employee in the directory — regardless of	1. Offboarding access revocation (operational): Immediately disable accounts when an employee's end date is reached, tied to HR workflows. 2. Role-based access control (technical): Apply least privilege —

	Robert Taylor Jr., a contractor whose end date was ~November 2020 — meaning his account should not have been active. The event was triggered from a computer named Up2-NoGud — suggesting a personal or unauthorised device was used.	role or status — holds Admin-level authorisation. This violates the principle of least privilege.	restrict payroll access to finance personnel only; contractors and part-time staff should have minimal permissions. 3. Periodic access reviews (managerial): Schedule quarterly audits to identify former employees or users with excessive privileges and deactivate/downgrade them promptly.
--	--	--	---

Key Takeaways

- Event logs are a primary tool for investigating incidents — they capture the who, when, where, and what of every system action. Correlating log data with other sources (like an employee directory) is essential for identifying threat actors.
- IP address correlation is a practical investigation technique: matching the IP from an event log to an employee record allowed me to identify the likely threat actor even though the account name alone was ambiguous.
- Stale accounts (belonging to former employees whose access was never revoked) represent a serious and often overlooked insider threat vector. In this case, a contractor retained full Admin access for nearly 3 years post-contract.
- The principle of least privilege (PoLP) is foundational to access control. Granting every employee Admin-level access regardless of their role eliminates all meaningful access boundaries and dramatically increases the attack surface.
- Effective access control requires controls at all three layers: technical (RBAC, system restrictions), operational (offboarding procedures), and managerial (regular audits and reviews).
- A single access control failure can enable financial fraud. The combination of an active stale account and unrestricted Admin access allowed a former contractor to initiate an unauthorised payroll transfer.

Skills Demonstrated

Analytical Skills	Security Knowledge	Professional Competencies
• Event log analysis • Cross-referencing data sources	• Access control concepts (AuthN/AuthZ)	• Incident investigation & reporting

• Threat actor identification • Pattern recognition in access data • Root cause analysis	• Principle of least privilege (PoLP) • Role-based access control (RBAC) • Identity & Access Management (IAM) • Technical, operational & managerial controls	• Structured worksheet documentation • Security recommendations to stakeholders • Risk mitigation planning • Clear written communication of findings
--	--	--

Conclusion

This activity simulated a real-world insider threat scenario that security analysts frequently encounter. By working through the investigation systematically — reviewing the event log, cross-referencing the employee directory, and applying knowledge of access control principles — I was able to identify both the immediate cause (a stale account) and the underlying systemic issue (no access control governance). The recommendations I provided address the problem at all three control layers, which is the approach a well-rounded security professional would take when advising a business on improving its security posture.